Replace VPN with Microsoft Entra Private Access: Zero Trust private apps on compliant devices

An expert, end-to-end playbook for replacing traditional VPN with Microsoft Entra Private Access: why VPN gateways and broad network access fail Zero Trust, licensing and roles, private network connectors, Quick Access versus per-app Enterprise applications, the Windows Global Secure Access client via Intune, Conditional Access that requires compliant devices, Intune compliance, pilot and VPN retirement, monitoring, troubleshooting and rollback.

10 phases | 30 steps | Tick each item when its "done when" criterion is true

Phase 1 Why replace VPN: risk, Zero Trust and where Private Access fits about 1–2 days

- [ ] **1.1 Name the failure modes of traditional VPN**
  A one-page threat model lists broad network access after auth, lateral movement after a single tunnel, and internet-exposed VPN / SSL VPN gateways as the three reasons you are leaving VPN
- [ ] **1.2 Place Private Access against Application Proxy and Internet Access**
  The design notes state which private resources go to Private Access, which web apps (if any) stay on Application Proxy, and that Internet Access / Microsoft traffic are out of scope for this VPN replacement
- [ ] **1.3 State the non-negotiable access rule for this guide**
  The project charter says private-app traffic is allowed only when Conditional Access grants access and the device is marked compliant by Intune; MFA / phishing-resistant and risk controls are layered on top

Phase 2 Prepare the tenant: licensing, roles, GSA activation and the Private Access profile about 1–3 days

- [ ] **2.1 Confirm licensing before you build anything**
  Every user who will use Private Access has Microsoft Entra ID P1 or P2 *and* Microsoft Entra Private Access (standalone) or Microsoft Entra Suite; guest licensing is checked against the current Learn page
- [ ] **2.2 Assign least-privilege roles for the build**
  Named admins hold Global Secure Access Administrator for GSA features, Application Administrator for connectors and Enterprise apps, Conditional Access Administrator for CA policies, and (for Intune) the Intune roles needed to deploy the client — preferably via PIM
- [ ] **2.3 Open Global Secure Access and plan the Private Access profile toggle**
  An admin can open Global Secure Access in the Entra admin center, and the runbook states that the Private Access traffic forwarding profile stays off until Quick Access or at least one Enterprise app, users and a report-only CA policy exist

Phase 3 Deploy private network connectors: sites, HA, network and updates about 2–5 days

- [ ] **3.1 Size and place connector servers per site**
  Each site that will publish private apps has Windows Server 2016 or later (with .NET 4.7.2+; connector 1.5.3437.0+ needs .NET 4.7.1+), TLS 1.2 enabled, recommended sizing (≥ 8 GiB RAM, ≥ 4 CPU cores), and is close on the network to the apps it serves
- [ ] **3.2 Open outbound network paths only — no inbound**
  From each connector host, TCP 80/443 reach the documented URLs (`*.msappproxy.net`, `*.servicebus.windows.net`, login and CRL endpoints), and no inbound firewall hole was opened for Private Access
- [ ] **3.3 Install, register and group connectors for HA**
  Each site has a named connector group with ≥ 2 connectors showing Active/green in `Global Secure Access > Connect > Connectors`, both Windows services (`Microsoft Entra private network connector` and updater) are Running, and a maintenance group exists for draining

Phase 4 Publish private apps: Quick Access, per-app Enterprise apps and private DNS about 3–10 days

- [ ] **4.1 Start with Quick Access — wide enough to replace VPN, narrow enough to defend**
  Quick Access exists with a connector group, ≤ 500 application segments, users/groups assigned (no nesting), and every segment is an FQDN, IP, CIDR or IP-to-IP range with explicit ports/protocols — not 'all ports on the whole RFC1918 space' unless a written exception says so

- [ ] **4.2 Enable private DNS suffixes for internal names and Kerberos**
  Private DNS is enabled on Quick Access with at least the Active Directory forest / primary internal suffixes; a pilot client resolves an internal FQDN only when the GSA client is connected
- [ ] **4.3 Carve high-value apps into per-app Enterprise applications**
  Each sensitive system (finance RDP, file servers, admin jump hosts, domain controllers for SSO, etc.) has its own Global Secure Access Enterprise application with least-privilege segments, its own connector group if isolation demands it, and its own user assignments
- [ ] **4.4 Publish domain controllers only when you need Kerberos SSO**
  If password or Windows Hello for Business SSO to on-premises resources is required, a dedicated Enterprise app publishes only the DCs in the connector site's AD site with the documented ports, and WHFB cloud Kerberos trust is configured when passwordless is in use

Phase 5 Deploy the Windows Global Secure Access client with Intune and lock it down about 2–4 days

- [ ] **5.1 Confirm device identity prerequisites**
  Pilot devices are Microsoft Entra joined or hybrid joined (registered-only is limited: Private Access only, with caveats), 64-bit Windows 10 LTSC 2021+ / Windows 11 (or Arm64 with the Arm installer), and `dsregcmd /status` shows a PRT
- [ ] **5.2 Package and deploy with Intune Win32 (Microsoft's documented method)**
  A Win32 app installs `GlobalSecureAccessClient.exe` via the documented PowerShell wrapper (`/quiet`, IPv4-preferred registry, reboot 3010), detection rules on `C:\Program Files\Global Secure Access Client\TrayApp\GlobalSecureAccessClient.exe`, and is assigned to a pilot group
- [ ] **5.3 Lock down the client so users cannot walk around Private Access**
  Remediation scripts (or equivalent MDM) set `RestrictNonPrivilegedUsers=1`, hide Sign out and Disable Private Access, and either hide Disable or accept that Disable still needs UAC admin; tray menu matches the policy
- [ ] **5.4 Verify on a pilot device with Health check and Advanced diagnostics**
  Tray icon shows Connected, Health check passes forwarding profile / tunneling / DNS / edge reachability for Private Access, and Forwarding profile shows the expected Quick Access / Enterprise segments

Phase 6 Conditional Access: compliant devices only for Private Access about 2–4 days

- [ ] **6.1 Design the policy set before clicking Create**
  A written matrix lists: (1) baseline policy for all Private Access apps / Quick Access requiring compliant device + MFA, (2) hardened policy for tier-0 apps requiring phishing-resistant strength, (3) optional risk-based layer, (4) explicit note that Private Access tunnel CA and compliant-network-on-Private-Access are out of scope per known limitations
- [ ] **6.2 Build the baseline Private Access CA policy in report-only**
  Policy exists: Users = all in-scope groups; Exclude = emergency access accounts; Target resources = Quick Access + Private Access apps; Grant = require MFA + require compliant device; Enable = Report-only
- [ ] **6.3 Add the hardened and risk layers**
  Tier-0 Private Access apps require phishing-resistant authentication strength; risk policies are either linked or explicitly deferred with a reason
- [ ] **6.4 Flip to On only after report-only evidence**
  Sign-in logs show Report-only success for pilot users on compliant devices, failures for known non-compliant test devices, and zero unexpected blocks for break-glass

Phase 7 Intune compliance that Conditional Access can trust about 2–5 days

- [ ] **7.1 Fix tenant-wide compliance policy settings first**
  `Mark devices with no compliance policy assigned as` is `Not compliant`, and compliance status validity period matches your operating reality (default 30 days unless you need tighter)
- [ ] **7.2 Deploy a Windows compliance baseline that matches the CA bar**
  Pilot devices report Compliant for a Windows policy that enforces at least: supported OS version, BitLocker/encryption, Secure Boot/TPM as appropriate, password/PIN, and Defender / threat-level expectations you already run

Phase 8 Pilot, dual-run with VPN, then retire the VPN about 4–12 weeks

- [ ] **8.1 Enable Private Access traffic forwarding for the pilot only**
  Private Access profile is on; Assignments limit users/groups and Windows platform to the pilot; Advanced diagnostics on a pilot PC shows the expected acquisition rules
- [ ] **8.2 Move from Quick Access to per-app with discovery data**
  After ≥ 2 weeks of pilot traffic, Application discovery has been reviewed; high-value segments are Enterprise apps with tightened groups; Quick Access no longer contains those segments

- [ ] **8.3 Retire VPN gateways and close the exposure**
  VPN client assignments removed for migrated cohorts; gateway public endpoints decommissioned or firewalled; residual VPN admin path documented; Watch-list classes of VPN CVE no longer apply because the appliance is gone

Phase 9 Monitor: traffic logs, sign-ins, export and alerting about 1–3 days, then ongoing

- [ ] **9.1 Use the portal dashboards and traffic logs daily in the pilot**
  Global Secure Access dashboard and `Monitor > Traffic logs` (preview) are bookmarked; a filter for Private Access + Denied exists; connector health is checked on the Connectors blade
- [ ] **9.2 Export NetworkAccess* tables to Log Analytics / Sentinel**
  A diagnostic setting sends at least `NetworkAccessTrafficLogs` (and ideally Connection, Alerts) to a Log Analytics workspace; a saved query shows Denied Private Access attempts

Phase 10 Troubleshooting and rollback about Ongoing

- [ ] **10.1 Triage with a fixed order: client → profile → connector → DNS → CA**
  The runbook lists Health check first, then Forwarding profile / Policy tester, then connector status/diagnostics, then private DNS / NRPT, then Entra sign-in log CA results
- [ ] **10.2 Roll back in layers — never jump straight to full VPN**
  Operators can: (1) switch a CA policy to Report-only or disable it, (2) remove a user from Private Access profile assignment, (3) disable Private Access profile, (4) re-enable VPN for a group — and know the order

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.github.io/guides/entra-private-access-vpn-replacement.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.